

📦 Flow Summary (Unauthenticated): User is logged out → Can't remember password.

Hits POST /forgot-password → enters email → receives OTP.

Enters OTP + new password in POST /reset-password.

Password is updated → now they can log in again.

☑ Strengths Correct use of cookies for session/token storage.

Proper OTP expiry and cooldown implementation.

Account TTL via deleteAt — great foresight.

Secure handling of forgotten password flows.

Clear response messages and error handling.

Use of Mongoose .save() ensures pre-hooks (like password hashing) are triggered.

Our schema of user

Field Purpose name User's display name email Login identifier, must be unique password Secure hashed password phoneNumber Optional contact (used for SMS, etc.) isVerified Tracks if user completed OTP verification otp Stores OTP (encrypted) otpExpires Defines OTP expiry time lastOtpSent Used for OTP resend cooldown logic deleteAt Auto-deletion for unverified temp accounts timestamps Adds createdAt and updatedAt fields

1. Fix some vulnerabilities
2. create functionality like

```
forgotPassword
resetPassword
resendOtp
```

3. changing schema of database
4. creating middleware